DRAFT - not yet reviewed by a solicitor. Replace all [bracketed] details before use.

Data Processing Agreement

This Data Processing Agreement ("DPA") forms part of the Terms of Service between [COMPANY NAME] Ltd (company number [COMPANY NUMBER], [REGISTERED ADDRESS]) (the "Processor") and the customer who accepts the Terms of Service (the "Controller"). It applies where the Processor processes personal data on behalf of the Controller when providing the Service, and is intended to meet Article 28 of the UK GDPR and the EU GDPR.

1. Subject matter, duration and nature

The Processor hosts and runs uptime monitoring, alerting and status pages for the Controller. Processing lasts for as long as the Controller has an account, plus the deletion period in section 9.

2. Types of personal data and data subjects

Personal data: names and email addresses or phone numbers of notification recipients, webhook and chat identifiers, status page contact details, and any personal data contained in monitored URLs or responses that the Controller chooses to submit.

Data subjects: the Controller's team members, customers and other individuals whose details the Controller enters into the Service.

3. Controller's instructions

The Processor will process personal data only on the Controller's documented instructions, which are the Terms of Service, this DPA and the Controller's use of the Service, unless required to do otherwise by law. The Processor will tell the Controller if it believes an instruction infringes data protection law.

4. Confidentiality

The Processor ensures that people authorised to process the personal data are bound by confidentiality obligations.

5. Security

The Processor will implement appropriate technical and organisational measures, including those in Annex 1, to protect personal data against accidental or unlawful destruction, loss, alteration, unauthorised disclosure or access.

6. Sub-processors

The Controller gives general authorisation for the Processor to engage the sub-processors listed at /sub-processors. The Processor will give notice of intended changes so the Controller can object on reasonable grounds. The Processor will bind each sub-processor to data protection obligations no less protective than this DPA and remains responsible for their performance.

7. Assistance

Taking into account the nature of processing, the Processor will assist the Controller, by appropriate measures, in responding to data subject requests and in meeting its obligations on security, breach notification, impact assessments and prior consultation.

8. Personal data breaches

The Processor will notify the Controller without undue delay, and where feasible within 48 hours, after becoming aware of a personal data breach affecting the Controller's personal data, and will provide information reasonably needed to meet reporting duties.

9. Deletion and return

When the Controller deletes its account or the agreement ends, the Processor will delete the Controller's personal data, including copies in the monitoring engine, within 30 days, unless law requires retention. On request before deletion, the Processor will provide an export of the Controller's data.

10. Audits

The Processor will make available information reasonably necessary to demonstrate compliance with this DPA and will allow for and contribute to audits by the Controller or its appointed auditor, on reasonable notice, no more than once a year unless required by a regulator or following a breach.

11. International transfers

The Processor will only transfer personal data outside the UK or EEA where a lawful transfer mechanism applies, such as an adequacy decision, the UK International Data Transfer Addendum or EU Standard Contractual Clauses.

12. Liability and governing law

Liability under this DPA is subject to the limits in the Terms of Service. This DPA is governed by the laws of England & Wales.

Annex 1 - Security measures

Encryption of data in transit (TLS) and encryption of stored credentials and secrets.

Access controls: authenticated access, least-privilege administration, and per-customer data isolation enforced on every request.

Rate limiting and abuse monitoring on authentication and API endpoints.

Regular backups and tested restoration procedures.

Logging of administrative actions and prompt patching of the monitoring engine and dependencies.